

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA5112 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)

Assessment Tool Weightage: 10%

QUESTIONS: 20

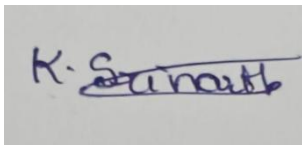
TOTAL MARKS: 20

Annexure A MOCK INTERVIEW

Code of Conduct:

I ____K.Srinath(192524220)____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

A rectangular box containing a handwritten signature in blue ink. The signature appears to be 'K. Srinath' written in a cursive style.

1. Which would you prioritize in a secure network design: performance or security, and how would you balance both?

Answer: Security should be the primary priority because a network that is fast but insecure can expose sensitive data and services to attackers. However, security should not unnecessarily reduce performance. I would balance both by using a risk-based approach, efficient firewall and IDS/IPS rules, network segmentation, load balancing, caching, and hardware acceleration where appropriate. The goal is to achieve strong protection with acceptable performance rather than choosing one at the complete expense of the other.

2. Can you explain the difference between stateful and stateless firewalls, and which one is more suitable for enterprise networks?

Answer: A stateless firewall evaluates each packet independently using rules such as source address, destination address, port, and protocol. It is simple and fast but does not understand the state of a connection. For most enterprise networks, a stateful firewall is more suitable because it provides stronger control over established connections and offers better protection against unauthorized traffic. Stateless filtering can still be useful for simple, high-speed filtering requirements.

3. If an IDS generates too many false positives, how would you optimize its performance?

Answer: I would first analyze the alerts to identify repeated false-positive patterns. Then I would also update IDS signatures and continuously validate the changes. Integration with SIEM correlation can further reduce alert noise by combining multiple events before raising a high-priority incident.

4. How would you design a real-time intrusion detection system for high-speed networks?

Answer: I would use a distributed architecture with sensors positioned at important network points. High-speed packet capture, efficient filtering, parallel processing, and scalable detection engines would be used to reduce processing delays. Signature-based detection can identify known attacks quickly, while anomaly-based techniques can identify unusual behavior. The system should also support load balancing, redundant sensors, secure communication, and continuous performance monitoring so that detection remains effective without becoming a network bottleneck.

5. What are the key challenges in detecting zero-day malware, and how would you address them?

Answer: Zero-day malware is difficult to detect because its behavior or indicators may not yet be known. Signature-based antivirus and IDS tools may therefore fail to identify it. I would address this using behavioral analysis, anomaly detection, sandboxing, endpoint detection and response, threat intelligence, application control, and network segmentation. Continuous monitoring and rapid incident response are also important because zero-day detection depends heavily on identifying abnormal behavior rather than relying only on known signatures.

6. How would you differentiate between signature-based and anomaly-based IDS, and when would you use each?

Answer: Signature-based IDS compares network activity with known attack patterns or signatures. It is highly effective for detecting known threats and usually produces understandable alerts, but it may miss new attacks. It can help identify unknown or zero-day attacks, but it may generate more false positives. In practice, I would use a hybrid approach that combines both methods so that known threats and unusual behavior can be detected together.

7. If a network is under a DDoS attack, what immediate and long-term mitigation strategies would you apply?

Answer: Immediately, I would confirm the attack, identify the affected services, and activate DDoS protection. I would use rate limiting, traffic filtering, ACLs, upstream provider assistance, and traffic scrubbing where available, baseline traffic analysis, and a tested incident-response plan. Regular DDoS simulations and coordination with the ISP would also improve preparedness.

8. How would you secure remote access to an enterprise network?

Answer: I would use a secure VPN or zero-trust remote-access solution with strong encryption and multi-factor authentication. Access should follow the principle of least privilege, giving users only the resources required for their roles. Device security should be verified through endpoint protection, patch status, and access policies. I would also use strong identity management, session timeouts, logging, monitoring, and conditional access based on risk. Remote administrative access should be especially restricted and closely monitored.

9. What are the limitations of traditional antivirus software, and how can modern solutions overcome them?

Answer: Traditional antivirus software mainly depends on known signatures, so it may not detect new or heavily obfuscated malware. It can also have difficulty identifying fileless attacks and malicious behavior that appears legitimate. Modern solutions improve protection by combining signatures with behavioral detection, machine-learning techniques, sandboxing, endpoint detection and response, threat intelligence, and real-time monitoring. These approaches focus not only on what a file looks like but also on what it does in the system and network.

10. How would you design a secure email filtering system to prevent phishing and spam attacks?

Answer: I would use multiple layers of email protection. The system should check sender reputation, domain authentication, and message content. SPF, DKIM, and DMARC should be configured to reduce email spoofing. Anti-spam and anti-phishing filters can inspect URLs, attachments, and suspicious patterns, while sandboxing can analyze potentially dangerous files. Messages with high-risk indicators should be quarantined for review. User awareness training, MFA, continuous monitoring, and regular updates to filtering rules should complement the technical controls.

11. If an attacker bypasses firewall rules, what additional layers of security would you implement?

Answer: I would use defense in depth rather than depending only on the firewall. Additional controls would include network segmentation, IDS/IPS, endpoint detection and response, strong identity and MFA, least-privilege access, secure configuration, vulnerability management, application security, encryption, and centralized logging. SIEM-based monitoring and incident-response procedures would help detect and contain an attacker even after perimeter defenses are bypassed.

12. How would you evaluate the effectiveness of network segmentation in preventing cyberattacks?

Answer: I would first identify the security zones and the communication allowed between them. I would then review firewall and ACL rules, verify that unnecessary cross-zone communication is blocked, and conduct vulnerability assessments or controlled penetration tests, lateral-movement opportunities reduced, and incidents contained within a segment. Logs and IDS/IPS alerts can also show whether segmentation is preventing suspicious traffic from reaching critical systems.

13. What role does encryption play in preventing malware attacks, if any?

Answer: Encryption does not directly prevent malware from infecting a system, but it protects the confidentiality and integrity of data and communications. TLS can protect network traffic from interception or tampering, while encryption at rest protects stored information. Secure cryptographic controls can also reduce opportunities for attackers to steal sensitive credentials and data during transit. However, encrypted traffic can sometimes hide malicious activity, so organizations should use appropriate traffic inspection, endpoint security, and monitoring while respecting privacy and policy requirements.

14. How would you secure a cloud-based network infrastructure?

Answer: I would apply a defense-in-depth and zero-trust approach. Cloud resources should use strong identity and access management, MFA, least privilege, network segmentation, security groups, secure APIs, encryption in transit and at rest, and centralized logging. Public exposure should be minimized and unnecessary ports should be closed. Vulnerability scanning, configuration monitoring, backups, incident response, and continuous security assessment are also necessary. Security responsibilities should be clearly divided between the cloud provider and the organization according to the shared-responsibility model.

15. What is the importance of log analysis and monitoring in network security?

Answer: Logs provide evidence of activities occurring across servers, endpoints, applications, firewalls, IDS/IPS, and other devices. Continuous analysis can reveal failed logins, unusual traffic, privilege changes, malware indicators, and possible attacks. Centralizing logs in a SIEM enables correlation of events from multiple sources and helps prioritize incidents. Logs are also valuable for investigation, compliance, troubleshooting, and forensic analysis. Therefore, accurate time synchronization, secure log storage, appropriate retention, and regular monitoring are essential.

16. How would you respond to a security breach in a corporate network?

Answer: I would follow a structured incident-response process: preparation, identification, containment, eradication, recovery, and lessons learned. First, I would confirm and scope the incident using logs and security alerts. I would isolate affected systems to prevent further damage while preserving evidence. Then I would remove the root cause, patch vulnerabilities, reset compromised credentials, and restore systems from trusted backups. After recovery, I would monitor for recurrence, document the incident, communicate with appropriate stakeholders, and improve controls based on the lessons learned.

17. What are the advantages and limitations of next-generation firewalls (NGFW)? Answer: NGFWs provide more advanced protection than traditional packet-filtering firewalls. They can combine stateful inspection with application awareness, user-based policies, intrusion prevention, URL or content filtering, and threat intelligence skilled configuration, and may introduce performance overhead when advanced inspection features are enabled. They should therefore be properly sized, regularly updated, and integrated with other security controls rather than treated as the only defense.

18. How would you integrate IDS/IPS with SIEM systems for better threat detection? Answer: I would configure IDS/IPS devices to send security events to the SIEM using secure and standardized log formats. The SIEM would normalize and correlate these alerts with firewall, endpoint, authentication, and application logs. Correlation rules can identify attack patterns that may not be obvious from a single alert. Alerts should be prioritized according to severity and asset importance. Automated responses can be used carefully for well-understood threats, while analysts investigate high-impact incidents. Regular tuning is necessary to reduce false positives and improve detection quality.

19. How would you integrate IDS/IPS with SIEM systems for better threat detection?

Answer: I would configure IDS/IPS devices to send security events to the SIEM using secure and standardized log formats. The SIEM would normalize and correlate these alerts with firewall, endpoint, authentication, and application logs. Correlation rules can identify attack patterns that may not be obvious from a single alert. Alerts should be prioritized according to severity and asset importance. Automated responses can be used carefully for well-understood threats, while analysts investigate high-impact incidents. Regular tuning is necessary to reduce false positives and improve detection quality

20. What are the best practices for patch management and vulnerability assessment?

Answer: Organizations should maintain an accurate inventory of hardware, software, and versions. Vulnerability scans should be performed regularly and vulnerabilities should be prioritized according to severity, exploitability, asset importance, and business impact. Security patches should be tested before deployment and then applied within defined timelines. Critical systems require special attention and emergency patching when necessary. Unsupported software should be replaced, exceptions should be documented, and patch compliance should be continuously monitored. Regular penetration testing can complement automated vulnerability assessments

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge
Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problem-solving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides well-structured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively
Confidence	15	Displays high confidence, positive attitude, and	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism